

Chapter 04 공개키 암호(4)

목차

4.1 개요

4.2 배낭암호

4.3 RSA

4.4 디피-헬먼

4.5 타원곡선 암호

4.6 공개키 표기법

4.7 공개키 암호 용도

4.8 인증서와 PKI

4.9 양자 컴퓨터와 공개키

4.10 요약

4.8 인증서와 PKI

➤ 공개키 암호 방식의 용도

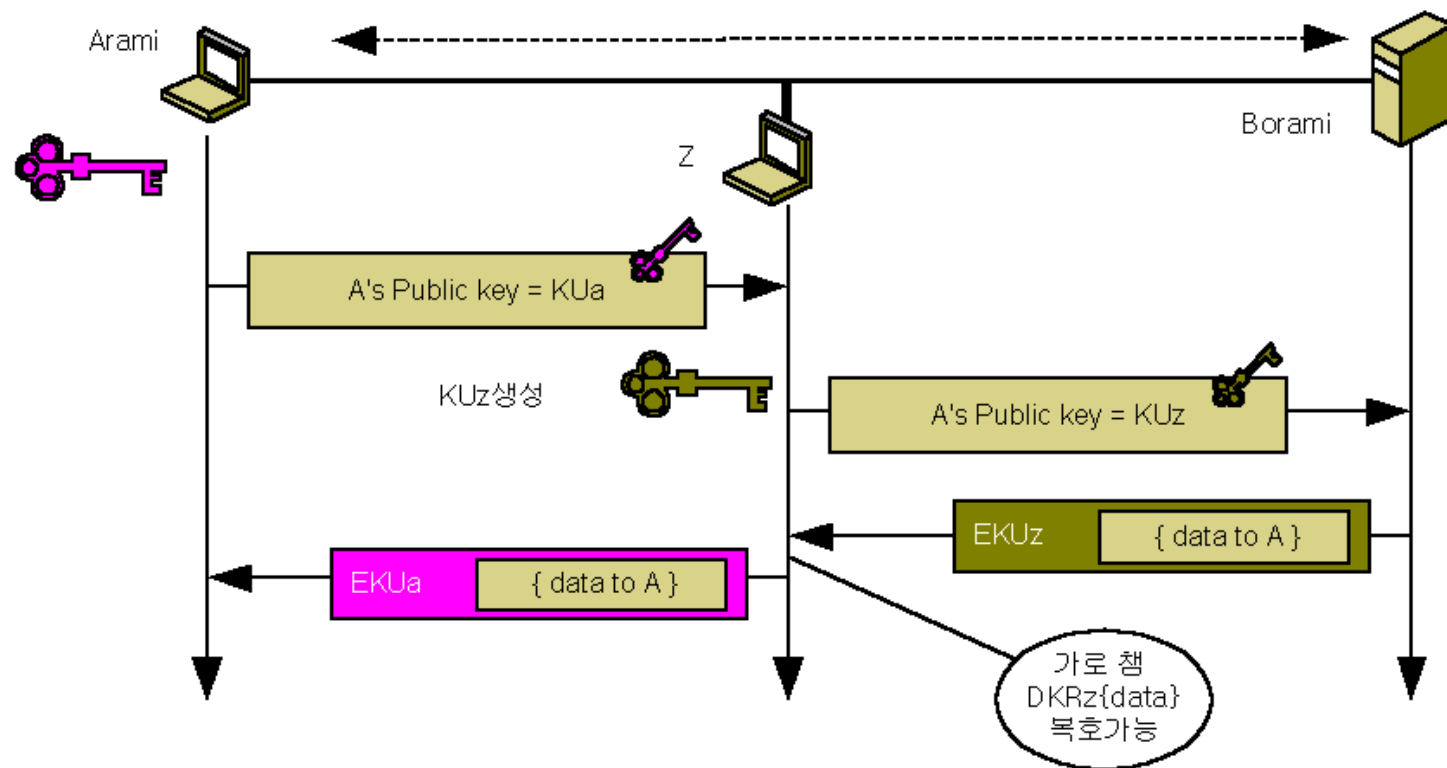
- 대칭키 암호 방식에 사용할 키 암호화에 사용
- 부인방지 및 사용자 인증을 제공하기 위해 전자 서명에 사용

➤ 공개키 암호 방식에서는 사용자마다 개인키/공개키가 존재

- 개인키는 자신만이 알 수 있도록 안전하게 보관
- 공개키는 다른 사람에게 공개하는 것이 원칙
 - 자신의 공개키를 다른 사람들에게 어떻게 전달할 것인가?

4.8 인증서와 PKI

➤ 공개키 전달의 문제점



중간자 공격에 취약

4.8 인증서와 PKI

➤ 안전한 공개키 전달 방식

- 공개키와 키 소유자의 사용자 ID 등으로 구성된 정보에 대해 신뢰할 수 있는 제 3자가 서명을 첨부
- 첨부된 전자서명이 유효한 경우, 공개키와 키 소유자의 ID가 변조되지 않았음을 확인할 수 있음(무결성 보장)
- 제3자는 정부기관이나 금융기관 같은 사용자들이 신뢰하는 기관으로 **인증기관(CA: certificate authority)**이라 함

4.8 인증서와 PKI

➤ 공개키 인증서(Public key certificate)

- 특정 **공개키가 사용자에게 결합되어 있음을 증명**하기 위해 인증기관(Certificate Authority)이 발행하는 디지털 정보
- 사용자의 신분 정보와 공개키를 암호학적으로 안전하게 결합하기 위해 **전자 서명** 이용

➤ 공개키 인증서의 생성 및 이용

- 사용자의 공개키 인증서는 인증서의 주체(subject), 공개키, 발행 일시, 발행자의 이름, 유효 기간 등을 포함
- 위의 데이터에 대해 **인증기관의 개인키를 이용하여 전자 서명**을 생성하여 인증서에 포함
- 사용자들은 **인증기관의 공개키를 이용하여 첨부된 서명을 검증**
- 서명이 유효한 경우, 인증서에 포함된 데이터가 변조되지 않았고 해당 인증서를 인증기관이 발행했다는 것을 신뢰(즉, 인증서에 포함된 공개키에 대해 신뢰하게 됨)

4.8 인증서와 PKI

➤ 공개키 인증서

- 신뢰할 수 있는 제 3의 기관(인증기관)이 사용자들에게 **공개키와 사용자의 신원정보에 대해 무결성을 검증할 수 있는 공개키 인증서를 발급**



표기된 이름과 주민등록번호가 서로 연관되어 있음을
신뢰할 수 있는 제3의 기관(구청)이 확인함을 의미

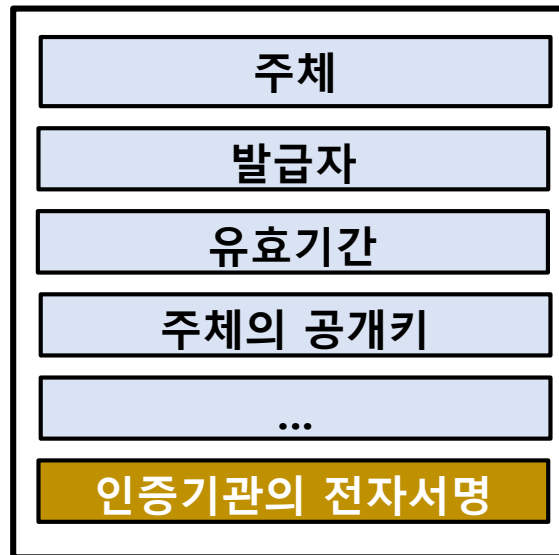


[신분증과 공개키 인증서]

4.8 인증서와 PKI

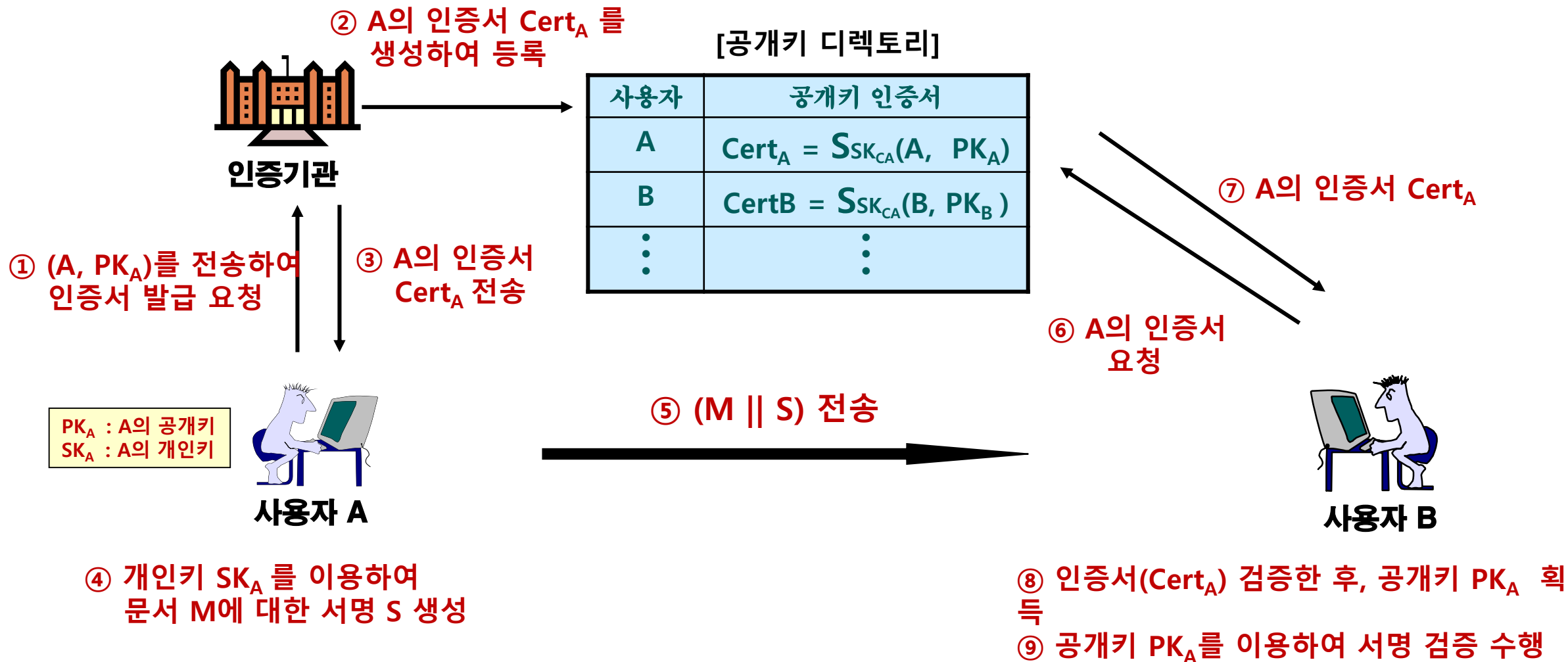
➤ 공개키 인증서

- 인증기관(CA)의 전자서명을 통해 공개키에 대한 무결성 확인
- 전자서명을 이용하여 서명한 사람이 누구인지를 확인할 수 있고, 전자 문서의 위/변조를 예방할 수 있으며, 거래사실을 증명할 수 있음

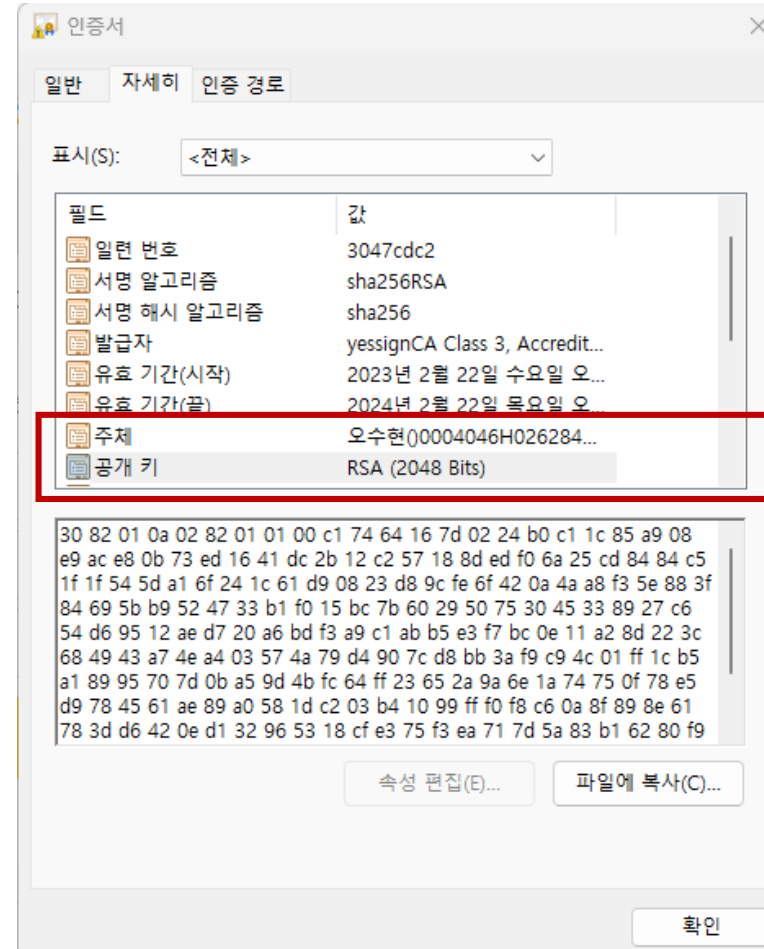
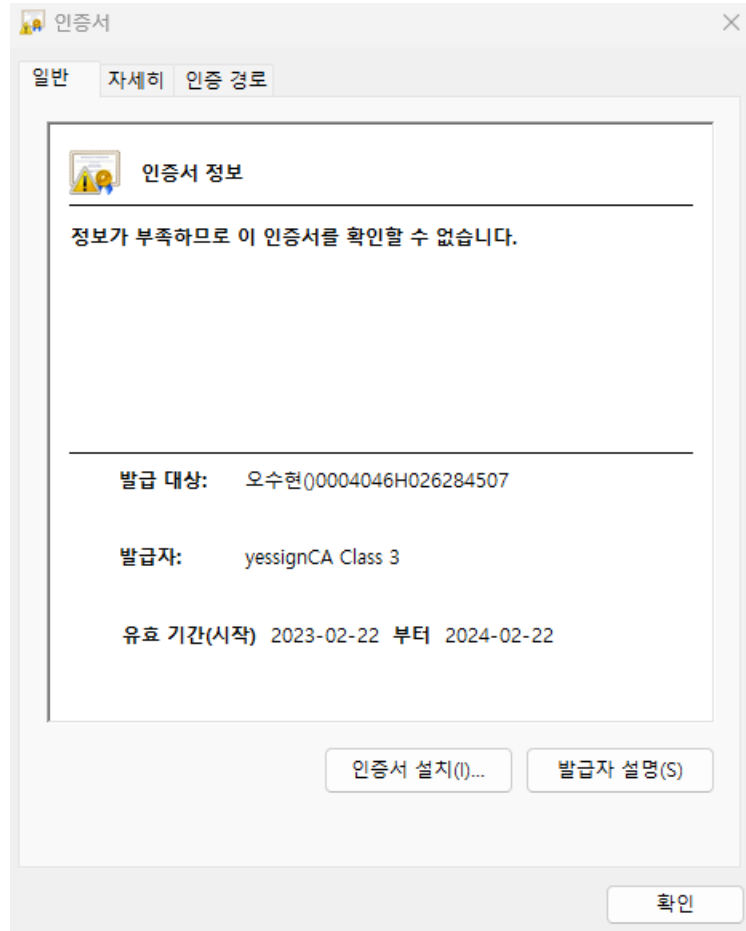


[공개키 인증서 구조]

4.8 인증서와 PKI



4.8 인증서와 PKI

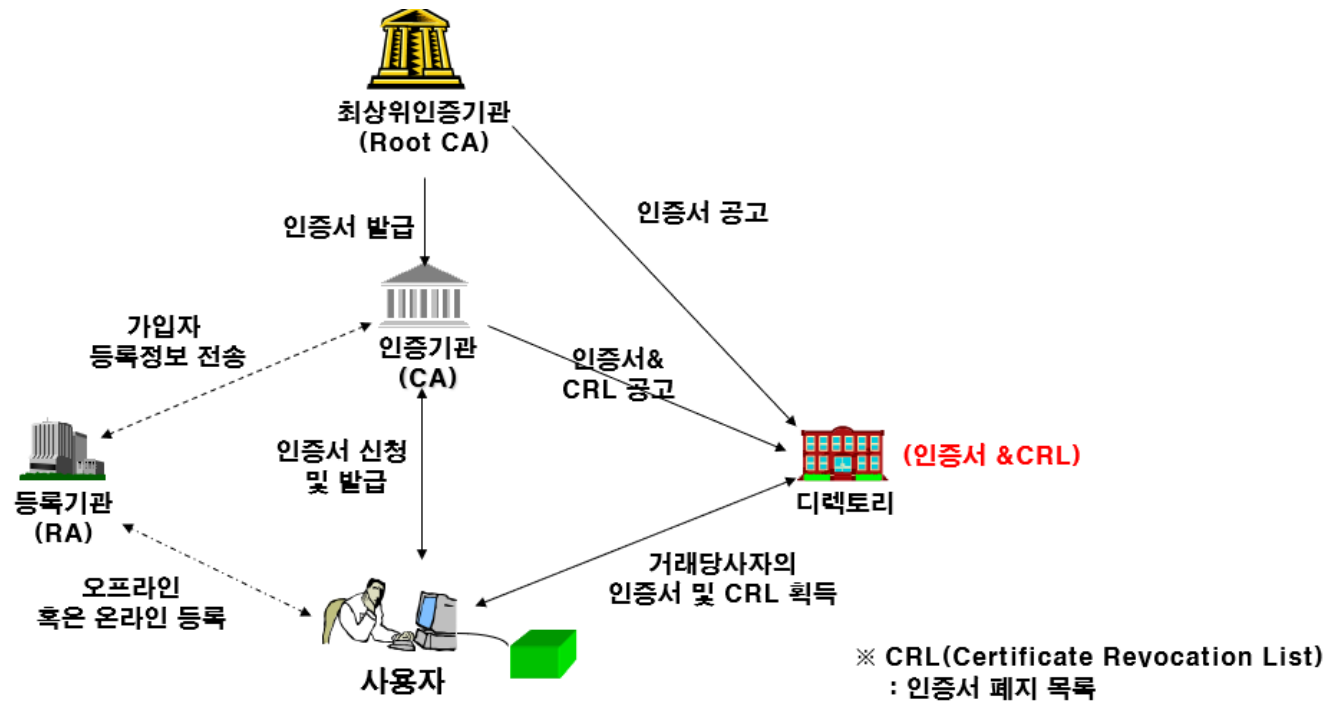


[사용자 인증서 예]

4.8 인증서와 PKI

➤ 공개키 기반구조(PKI :Public Key Infrastructure)

- 공개키 암호의 사용을 촉진하기 위하여 설계된 기반구조로서 **인증서와 인증서 취소목록(CRL :Certificate Revocation List)의 생성하고 분배**하는 전체 구조를 의미함



PKI의 구성 요소

➤ 최상위 인증 기관

- 인증 기관의 인증서를 발급해주는 기관
- 국내 최상위 인증 기관 : 한국인터넷진흥원 전자서명인증관리센터(<http://www.rootca.or.kr>)

➤ 인증기관(CA : Certification Authority)

- 사용자 인증서를 발급해주며, 인증서는 최종 객체를 인증하는 전자 증명서 역할
- 사용자의 공개키와 신분 정보에 대해 인증 기관의 개인로 서명한 서명 값 추가
- 공개키 기반구조를 구성하는 가장 핵심 객체
- 현재 국내에는 5개의 공인인증기관이 있음

PKI의 구성 요소

➤ 등록 기관(RA)

- Registration Authority
- **사용자의 신분을 확인**하고, 인증서 발급에 필요한 정보를 CA에게 보내는 역할
- 사용자와 CA 사이의 인터페이스를 제공

➤ 디렉토리(Directory)

- 인증서와 인증서 취소 목록(CRL)을 저장하는 곳
- 디렉토리에 접근하여 다른 사용자들의 인증서를 얻을 수 있음

공개키 인증서

➤ 인증서의 특성

- 누구나 사용자의 인증서를 획득하고 인증서로 부터 공개키를 획득할 수 있음
- 인증기관 이외에는 인증서를 수정하거나 발급할 수 없음
- 인증서를 발급한 인증 기관의 공개키를 이용하여 인증서를 검증한 후, 인증서가 정당한 경우 해당 인증서에 포함된 공개키를 신뢰할 수 있음
- 유효기간이 지난 인증서는 더 이상 신뢰하지 않음

공개키 인증서

➤ 최상위 인증기관 인증서

인증서

일반자세히인증 경로

인증서 정보

인증서의 용도:

- 원격 컴퓨터의 신분을 확인합니다.
- 원격 컴퓨터에 사용자의 신분을 증명합니다.
- 전자 메일을 보호합니다.
- 소프트웨어 게시자에게서 온 소프트웨어를 확인합니다.

발급 대상: KISA RootCA 1

발급자: KISA RootCA 1

유효 기간(시작) 2005-08-24 부터 2025-08-24

발급자 설명(S)

확인

인증서

일반자세히인증 경로

표시(S): <전체>

필드	값
버전	V3
일련 번호	04
서명 알고리즘	sha1RSA
서명 해시 알고...	sha1
발급자	KISA RootCA 1, K...
유효 기간(시작)	2005년 8월 24일 ...
유효 기간(끝)	2025년 8월 24일 ...
주체	KISA RootCA 1, K...
공개 키	RSA (2048 Bits)

30 82 01 08 02 82 01 01 00 bc 04 e4 fa 13 39 f0 34 96 20 6b 6c 68
bb fa db 77 ff 27 f7 ac ec 2f e7 fd f0 7f 6d 6f 8c 2a cd 25 09 5b 24
f4 a1 68 fc 28 ec c9 25 e2 ac ed de c8 33 84 f5 b0 a5 09 3a a7 b1
47 48 c5 cc 4f 8c 79 9c f9 06 57 7d dd ee 38 f6 cf 14 b2 9c ea d3 c0
5d 77 62 f0 47 0d b9 1a 40 53 5c 64 70 af 08 5a c0 f7 cf 75 f9 6c 8d
64 28 1e 20 fe b7 1b 19 d3 5a 66 83 72 e2 b0 9b bd d3 25 15 0d 32
6f 64 37 94 85 46 c8 72 be 77 d5 6e 1f 28 2f c7 69 ed e7 83 89 33
58 d3 de a0 bf 40 e8 43 50 ee dc 4d 6b bc a5 ea a6 c8 61 8e f5 c3
64 af 06 15 dc 29 8b 3f 75 8c bc 71 44 db fc ad b5 17 1d 6d 89 83

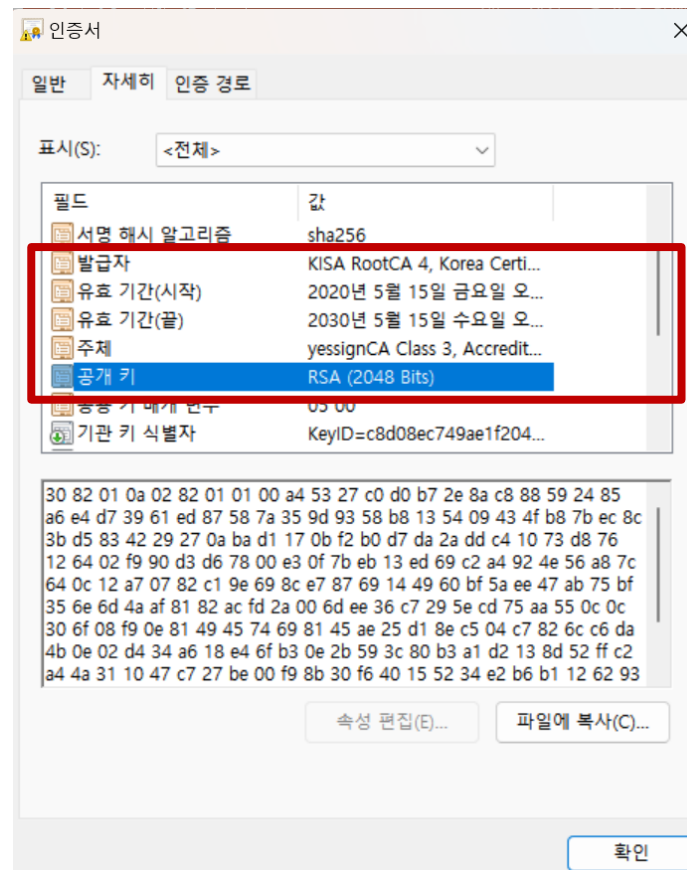
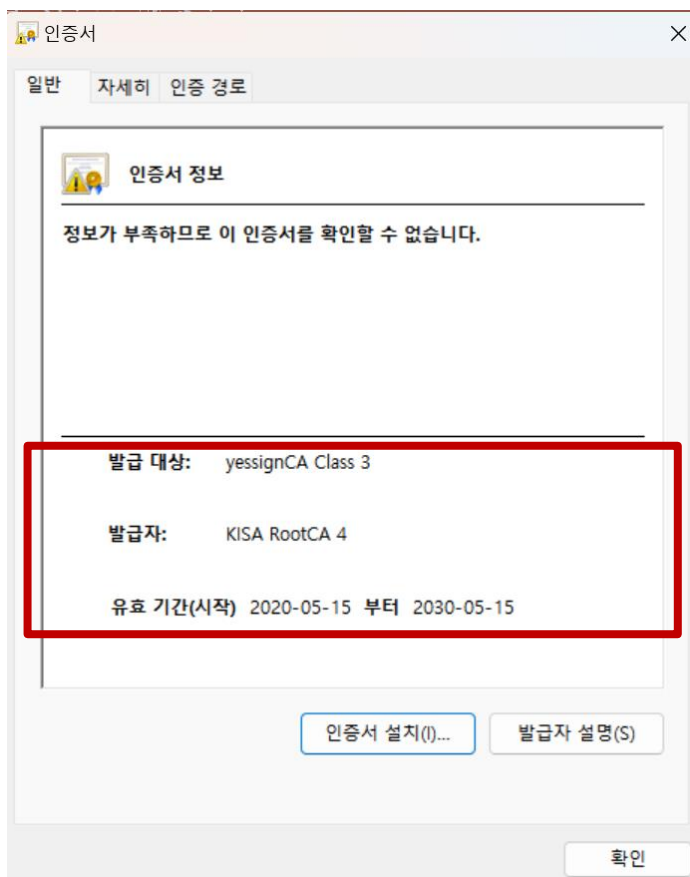
속성 편집(E)...

파일에 복사(C)...

확인

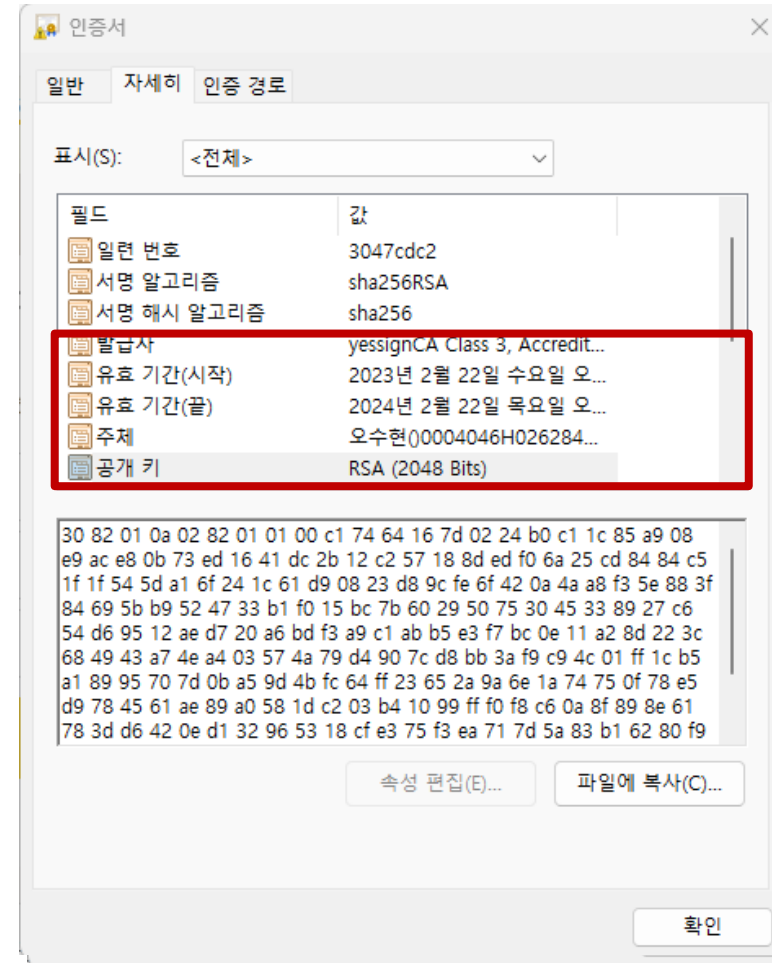
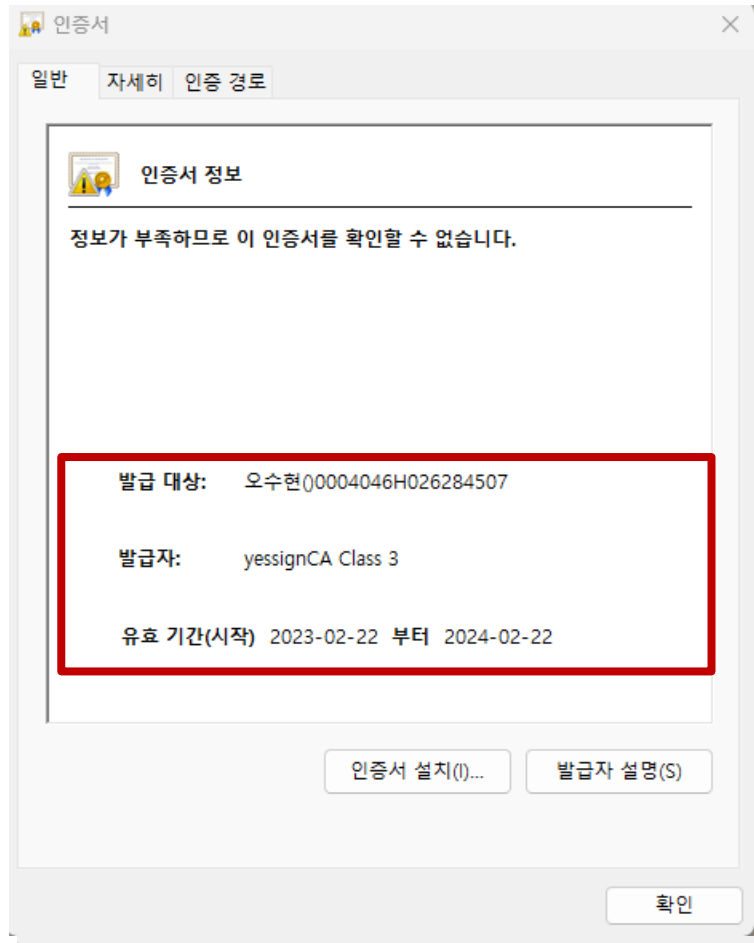
공개키 인증서

➤ 인증기관 인증서 - yessign 인증서

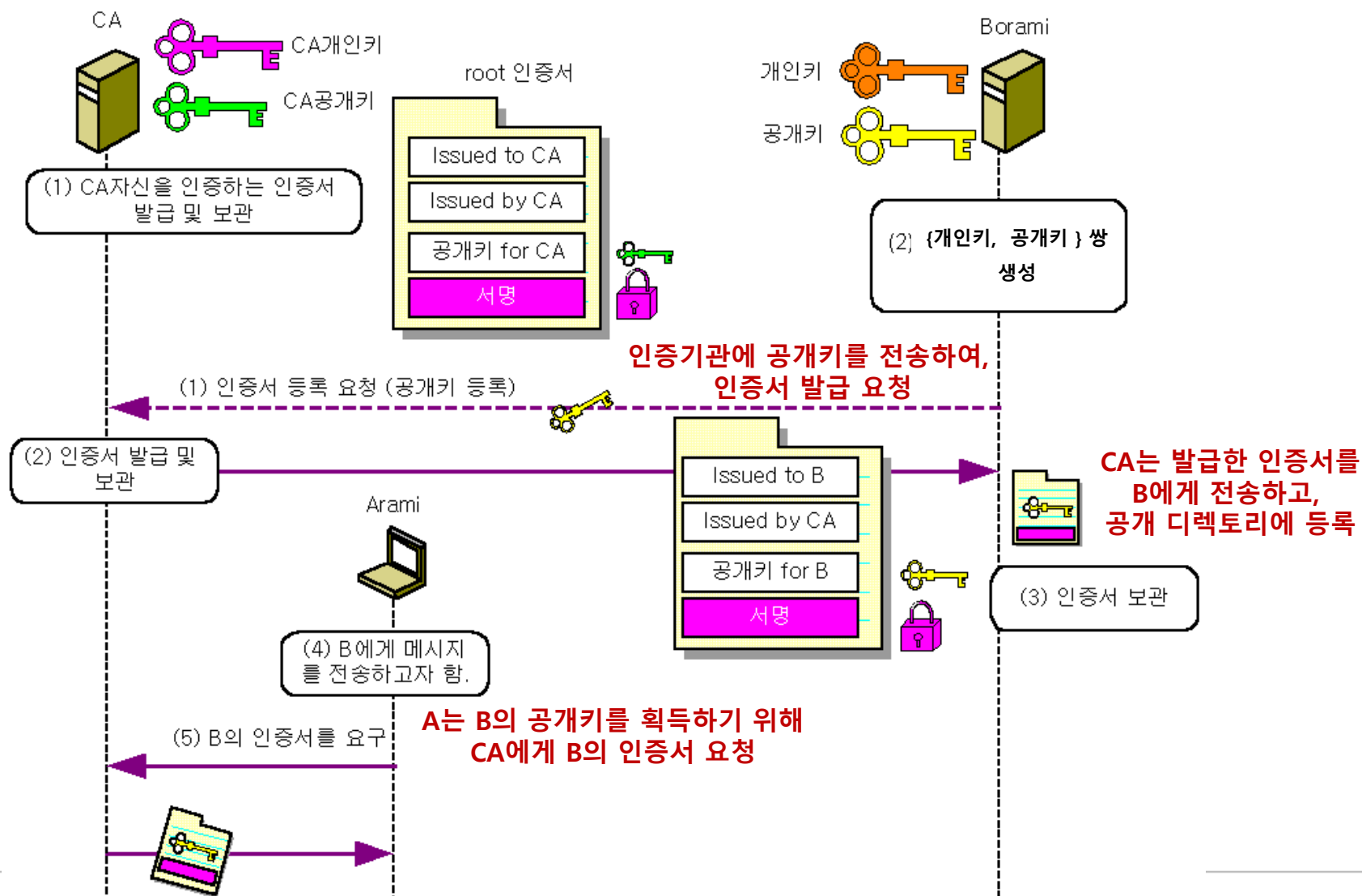


공개키 인증서

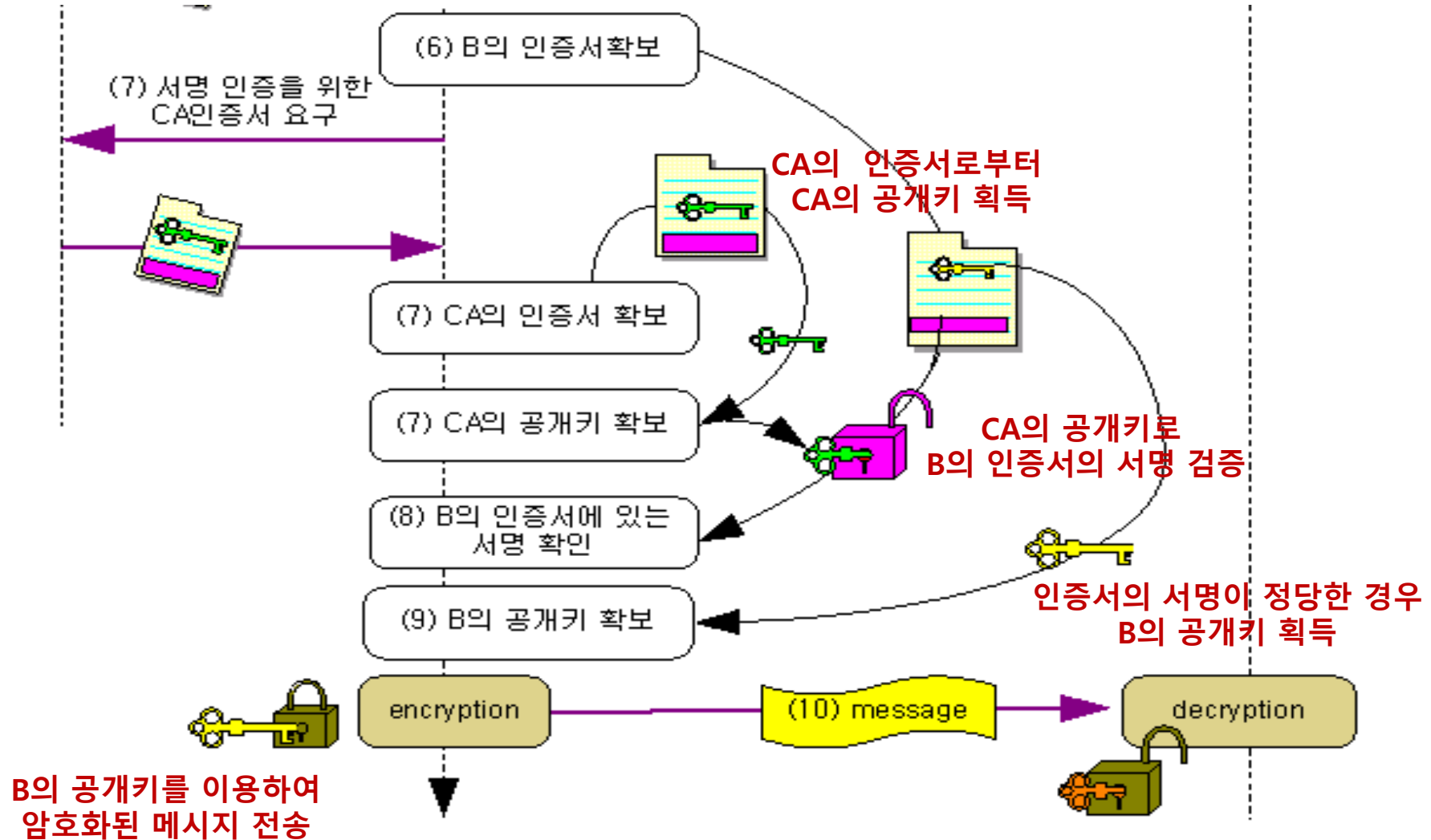
➤ 사용자 인증서



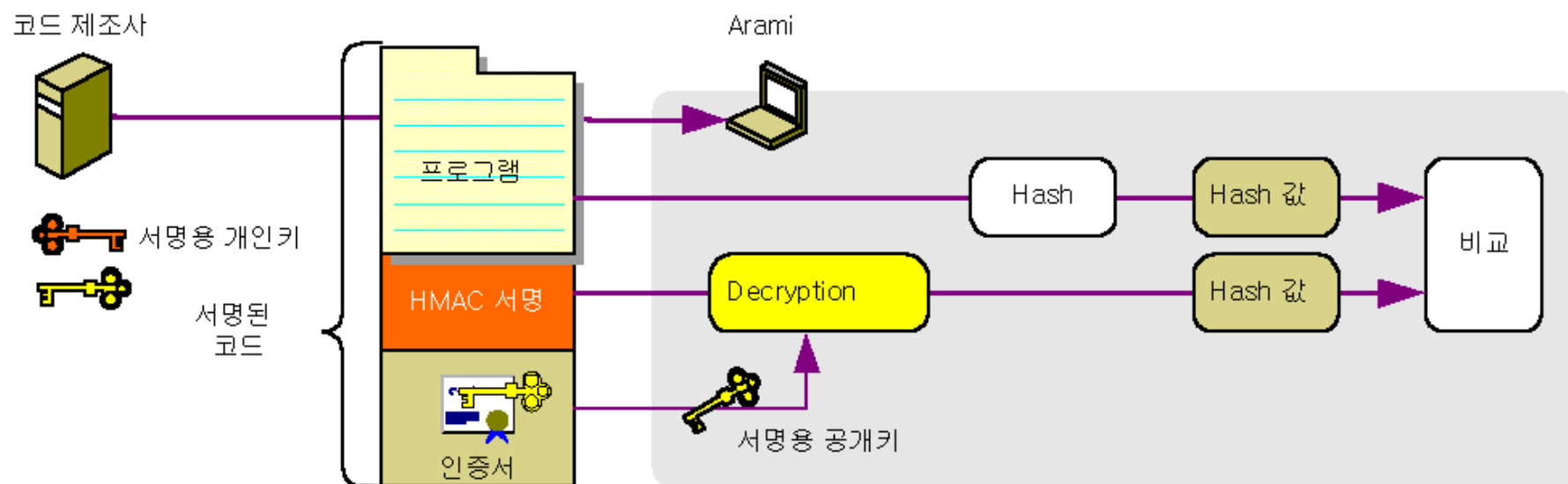
인증서 기반의 공개키 암호화 방식 사용



인증서 기반의 공개키 암호화 방식 사용



인증서 활용 예



➤ 민간 전자서명 인증체계(NPKI, National Public Key Infrastructure)

- 1999년 2월 전자문서의 안전성과 신뢰성을 확보하고 이용을 활성화하기 위하여 전자서명에 관한 기본적인 사항을 정한 「**전자서명법**」 제정
- **공인인증서**는 우리나라의 전자서명제도 도입 초기에 광범위하게 활용되면서 전자상거래 활성화 등 국가정보화에 크게 이바지 함
- 공인인증서가 시장독점을 초래하고 전자서명 기술의 발전과 서비스 혁신을 저해하며, 다양하고 편리한 전자서명에 대한 국민의 선택권을 제한한다는 등의 문제점 제기
- 전자서명의 신뢰성을 제고하면서 국민의 전자서명인증서비스 선택권 제공을 위하여 **전자서명인증사업자 인정·평가 제도**를 신규 도입한 개정 「전자서명법」이 2020년 12월 시행
 - 공인인증서 제도가 폐지되고 “공동인증서” 또는 “민간 전자서명”들이 동등한 법적 지위를 갖도록 변화

국내 PKI 동향



국내 PKI 동향



➤ 전자서명인증사업자 인정·평가 제도

- 민간 평가기관이 전자서명인증업무 운영기준 준수사실 여부를 평가하여 해당 결과의 적정성을 검토하고, 인정기관에서 인정 여부를 결정하는 제도
 - 과학기술정보통신부 : 전자서명의 안전성·신뢰성 및 다양성 제고 등을 위한 정책 수립
 - 한국인터넷진흥원 : 전자서명인증업무 운영기준 준수사실 인정 여부 결정 및 인정 취소 등 업무 수행
 - 평가기관은 평가를 신청한 전자서명인증사업자의 운영기준 준수 여부에 대한 평가 업무수행



[전자서명인증사업자 인정·평가 체계]

[평가기관 선정 현황]

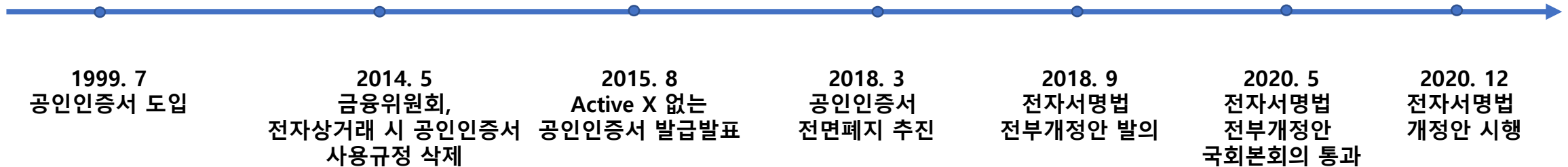
연번	평가기관	선정일
1	한국정보통신기술협회	2020. 12. 22.
2	금융보안원	2020. 12. 22.
3	딜로이트(안전회계법인)	2020. 12. 22.
4	KPMG(삼정회계법인)	2022. 4. 18.

[증명서 발급 현황]

인정번호	업체명	인정범위	유효기간
제 2021-001호	엔에이치엔페이코(주)	PAYCO 인증서비스	~ 2024년 08월 25일
제 2021-002호	(주)신한은행	신한인증서	~ 2024년 09월 14일
제 2021-003호	네이버(주)	네이버 인증서 서비스	~ 2024년 09월 16일
제 2021-004호	(주)국민은행	KB국민인증서 서비스	~ 2023년 10월 13일
제 2021-005호	금융결제원	YesKey 인증서 서비스 (공동인증서 및 금융인증서)	~ 2023년 10월 20일
제 2021-006호	한국정보인증주식회사	공동인증서비스	~ 2023년 11월 03일
제 2021-007호	(주)비바리퍼블리카	토스 인증서	~ 2023년 11월 10일
제 2021-008호	주식회사 뱅크샐러드	뱅크샐러드 인증서	~ 2023년 11월 10일
제 2021-009호	주식회사 카카오	카카오 인증서	~ 2023년 11월 21일
제 2021-010호	(주) 코스콤	코스콤 SignKorea 인증서비스	~ 2023년 11월 21일

인정번호	업체명	인정범위	유효기간
제 2021-011호	한국전자인증주식회사	CrossCert 전자인증서비스 (공동인증서)	~ 2023년 11월 25일
제 2021-012호	(주)한국무역정보통신	TradeSign 인증서비스 (공동인증서)	~ 2023년 12월 06일
제 2021-013호	주식회사 하나은행	하나OneSign 인증서 서비스	~ 2023년 12월 29일
제 2021-014호	에스케이텔레콤(주)	SK텔레콤 PASS 인증서 서비스	~ 2023년 12월 29일
제 2021-015호	(주)케이티	KT PASS 인증서	~ 2023년 12월 29일
제 2021-016호	(주)한국정보인증	S-PASS인증서비스	~ 2023년 12월 29일
제 2022-001호	(주)드림시큐리티	드림인증 전자서명 서비스	~ 2024년 02월 07일
제 2022-002호	NH농협컨소시엄	NH모바일인증서	~ 2024년 08월 16일
제 2022-003호	주식회사 카카오뱅크	카카오뱅크 인증서 서비스	~ 2023년 12월 28일
제 2023-001호	(주)우리은행	우리WON인증 서비스	~ 2024년 02월 09일
제 2023-002호	(주)엘지유플러스	LGU+ PASS 전자서명인증서비스	~ 2024년 02월 16일

➤ 국내 공인인증서의 도입에서 폐지까지



- 1999년 도입된 공인인증서는 오랫동안 전자금융거래, 전자정부 서비스, 온라인 민원 같은 인증/전자서명 수단으로 활용됨
- 사용자 불편, 기술 변화, 국제 추세 등을 이유로 2020년 말 전자서명법이 개정되어 공인인증서의 법적인 우월적 지위가 폐지됨
- 기존 공인인증서 발급 기관들이 발급하던 인증서를 계속 쓸 수 있으며, 법 개정 후 발급되는 인증서들은 공동인증서라 함
- 법 개정 이후에는 민간 전자서명(사실 인증서) 사업자들이 증가하고 있고, 이들이 공동인증서와 동등한 효력을 갖도록 인증제도가 정비됨

[대표적인 민간 인증서(사설 전자서명) 서비스]

구분	특징
PASS 인증 (이동통신사)	모바일 중심 간편 인증 제공 ESIM/앱 기반 인증이 수월
카카오 인증	카카오톡과 연계하여 생체 인증 또는 간편 비밀번호 사용 가능 사용자 접근성 높음
네이버 인증 등	다양한 플랫폼과의 연동 유저 베이스 활용성이 좋음
금융 인증 서비스 (금융결제원 주도)	클라우드 기반 인증서 보관, OS/브라우저 간 호환성 개선, 설치 프로그램 간소화 등의 장점이 있음

카카오 인증 예

- 공개키 암호방식 이용
- 모바일 친화적으로 단순화 한 서비스
- 사용자별로 개인키/공개키 생성
 - 개인키 : 사용자의 스마트 폰 보안 영역에 저장
 - Android : ARM Trust Zone(TEE)
 - iOS : Secure Enclave
 - 공개키 : 카카오 서버에 보관
- 전자서명에 사용하는 알고리즘 : ECDSA

카카오 인증 예

[사용자 키 쌍 생성 및 등록 단계]

모바일 단말



1. 기기 내 TEE/Secure Enclave에서
개인키/공개키 생성
(키는 기기 내부에서만 생성되고,
개인키는 내부 보안영역에 저장)

공개키 전송



카카오 서버



2. 사용자의 계정정보와 공개키 저장
{UserID, PubKey(공개키)}

※ 공개키는 카카오 서버에 등록되고, X.509 인증서 형태는 아님

카카오 인증 예

[본인 확인 과정]

서비스 제공자



카카오 서버



모바일 단말



1. 사용자 인증 요청

2. 랜덤 수 전송

Challenge

3. 카카오 톡 앱 수신

4. 생체인증 또는 비밀번호를 이용한 본인 확인

5. 본인확인 완료 후 개인키를 이용한 서명 생성

6. Signature 전송

Signature = Sign(challenge, 개인키)

9. 인증 승인 결과 전송

7. 서버에 저장한 공개키로 서명 검증
Verify(Signature, Challenge, 공개키)

8. 검증에 성공하면 인증 승인

카카오 인증 예

➤ 카카오 인증서의 특징

- 공개키는 서버가 계정별로 안전하게 저장하고, 개인키는 스마트폰 내부 보안영역에만 존재
- 사용자의 개인키는 절대 외부로 전달되지 않으며, 서명 생성을 위해 생체인증을 이용한 본인 확인 수행
- 서명은 기기에서만 수행되고 서명 결과만 서버로 전송하여 공개키로 검증
- 사용자들의 공개키는 중앙 서버에서 관리(인증서 형태가 아님)
- 외부 서비스(은행/정부 등)가 직접 서명을 검증하지 않고, 카카오 서버가 중간에서 서명 검증을 대행하는 구조 → 공개키를 전송할 필요가 없음
 - 외부 서비스는 카카오 서버만 신뢰하면 됨
 - 공개키가 전송되지 않으므로, 인증서 형식이 필요하지 않음(전통적인 PKI 구조가 필요하지 않음)
 - 카카오 서버에 장애가 발생하면 서명 검증도 불가

4.9 양자 컴퓨터와 공개키

➤ 양자 알고리즘(quantum algorithm)

- 1994년에 피터 쇼어(Peter Shor)는 **인수분해 문제에 대해 효율적인 해결책 제공할 수 있는 쇼어 알고리즘 발표**
- 인수분해는 계수를 인수분해하여 RSA를 해독할 수 있음
 - RSA 계수는 정수 $N=pq$ 이며, p 와 q 는 소수
- 2019년 구글 양자 컴퓨터 연구팀에서는 2048 비트 자연수를 양자 컴퓨터를 이용해 소인수 분해하기 위해서는 대략 8시간 정도의 시간이 걸린다고 주장
- 예) $n=2048$ 비트인 RSA 계수를 인수분해하기 위한 연산량
 - 기존 알고리즘은 125비트 이상의 대칭키를 찾기 위한 검색과 비슷한 노력을 해야 함
 - 반면에 같은 크기의 RSA 계수에 대해 쇼어 알고리즘은 30비트 대칭키를 찾기 위한 검색보다 더 적은 노력을 들여도 됨

4.9 양자 컴퓨터와 공개키

➤ 양자내성 암호(Post-Quantum Cryptography)

- 양자컴퓨팅 환경에서 안전하게 암호기술을 이용할 수 있도록 하는 새로운 공개키 암호 방식
- 양자컴퓨팅 및 양자암호 업계에서는 2030년이 되면 현 공개키 암호를 해독할 수준의 양자 컴퓨터 가 상용화될 것으로 예상
- 이에 따라 암호학적으로 해독이 가능한 양자컴퓨터가 출현하기 전 현재의 RSA, ECC 등 모든 공개키암호 알고리즘에 대해서 양자내성암호로 전환 준비 중

| 국내 표준 양자내성암호 알고리즘

참여기관	알고리즘명	기반문제	기능
서울대/KISA	Rlizard	격자	PKE/KEM
국가수리연구소	HiMQ	다변수	전자서명

※ LG U+ 광통신 장비에 Rlizard를 적용하는 사업이 추진되었으며, 2021년에는 KISA 주관으로 잉카인터넷의 nProtect, NSHC의 nFilter, 이스트시큐리티의 MIST 등 국내 3개 정보보호업체의 서비스에 Lizard/Rlizard 및 국외 알고리즘을 시범적으로 ICT 서비스에 적용 및 실증 진행

4.10 요약

- 공개키 암호 알고리즘은 수학적으로 해결하기 어려운 문제들을 이용하며, 소인수분해 문제를 이용한 RSA 암호 시스템이 가장 널리 사용됨
- Diffie-Hellman 키 교환 방식은 이산대수 문제를 이용하며, 안전하지 않은 채널을 이용하여 두 개체간에 공유 비밀키를 구축하는 방법을 제공함
- 타원곡선상의 이산대수 문제를 이용하는 타원곡선 암호방식(ECC)은 짧은 키 길이로 인해 연산량이 비교적 적으므로 다양한 분야에서 활용되고 있음
- 공개키 암호 방식은 대칭키 암호 방식에 비해 많은 연산량을 요구하므로, 실제 응용환경에서는 하이브리드 암호 체계를 이용
- 공개키 암호방식은 해당 사용자만이 알고있는 비밀정보인 개인키가 존재하므로, 이를 이용하여 전자 서명을 생성하는 경우 부인방지 및 출처 인증을 제공할 수 있음
- 공개키 암호 방식에서는 공개키의 무결성을 보장할 수 있는 방법이 요구되며, 공개키 인증서와 PKI를 이용하여 해결할 수 있음
- 양자 컴퓨터 환경에서 소인수분해나 이산대수 문제를 이용한 공개키 암호 방식을 해독하는 알고리즘이 개발됨에 따라 양자 내성 암호 등 대안 개발 중